

Unit 5

Security in E-Commerce

- Introduction
- Dimensions of E-commerce Security: Confidentiality, Integrity, Availability, Authenticity, Nonrepudiation, Privacy
- Security Threats in E-commerce
- Vulnerabilities in E-commerce: Malicious Code, Adware, Spyware, Social Engineering, Phishing, Hacking, Credit card fraud and Identity theft, Spoofing and Pharming
- Client and Server Security, Data Transaction Security
- Security Mechanisms: Cryptography, Hash Functions, Digital Signatures, Authentication, Access Controls, Intrusion Detection System, Secured Socket Layer(SSL)

Link to Slides:

<https://drive.google.com/drive/folders/1HfVEv3IX-JCCeYJM4vXDN2Ac77PJTyfb?usp=sharing>

E-commerce security

- the Internet and Web are increasingly vulnerable to large-scale attacks and potentially large-scale failure.
- Increasingly, these attacks are led by organized gangs of criminals operating globally
- There is also the growing number of large-scale attacks that are funded, organized, and led by various nations against the Internet resources of other nations.
- Anticipating and countering these attacks has proved a difficult task for both business and government organizations.
- However, there are several steps we can take to protect our websites, mobile devices, and personal information from routine security attacks.
- Food for thought: how our business could survive in the event of a large-scale “outage” of the Internet?

some of the major recent trends in online security

- Large-scale data breaches that expose data about individuals to hackers and other cybercriminals.
- Mobile malware threat. Smartphones and other mobile devices have become targets of cybercriminals, especially as their use for mobile payments rises.
- Malware creation continues to skyrocket and ransomware attacks.
- Distributed Denial of Service (DDoS) attacks are now capable of slowing Internet service within entire countries.
- Nations continue to engage in cyberwarfare and cyberespionage.
- Hackers and cybercriminals are focusing their efforts on social network sites to exploit potential victims through social engineering and hacking attacks.
- Politically motivated, targeted attacks by hacktivist groups continue, in some cases merging with financially motivated cybercriminals to target financial systems with advanced persistent threats.
- Software vulnerabilities, such as the Heartbleed bug and other zero day vulnerabilities, continue to create security threats.

Note:

social engineering: In the context of information security, social engineering is the psychological manipulation of people into performing actions or divulging confidential information. **Social engineering** is the term used for a broad range of malicious activities accomplished through human interactions. It uses psychological manipulation to trick users into making security mistakes or giving away sensitive information.

Heartbleed bug: The Heartbleed Bug is a serious vulnerability in the popular OpenSSL cryptographic software library. This weakness allows stealing the information protected, under normal conditions, by the SSL/TLS encryption used to secure the Internet. The Heartbleed bug allows anyone on the Internet to read the memory of the systems protected by the vulnerable versions of the OpenSSL software. This compromises the secret keys used to identify the service providers and to encrypt the traffic, the names and passwords of the users and the actual content. This allows attackers to eavesdrop on communications, steal data directly from the services and users and to impersonate services and users. This bug was discovered in 2014.

Zero day vulnerability : A zero-day vulnerability is a computer-software vulnerability that is unknown to those who should be interested in mitigating the vulnerability. Until the vulnerability is mitigated, hackers can exploit it to adversely affect computer programs, data, additional computers or a network. A **zero-day vulnerability** is a software security flaw that is known to the software vendor but doesn't have a patch in place to fix the flaw. It has the potential to be exploited by cybercriminals. It means the vulnerability has been disclosed but not yet solved.

DIMENSIONS OF E-COMMERCE SECURITY

- There are six key dimensions to e-commerce security:

1. Integrity :

- Integrity means correctness.
- It refers to the ability to ensure that any information being displayed on a website, or transmitted or received over the Internet, is correct and has not been altered in any way by an unauthorized party.
- For example, if an unauthorized person intercepts and changes the contents of an online communication, such as by redirecting a bank wire transfer into a different account, the integrity of the message has been compromised because the communication no longer represents what the original sender intended.

2. Nonrepudiation :

- repudiation means denying one's own actions.
- Nonrepudiation refers to the ability to ensure that e-commerce participants do not deny (i.e., repudiate) their online actions.
- For instance, a person can post comments or send a message and later he/she can deny doing so.
- It is easy for that customer to order merchandise online and then later deny doing so. In most cases, because merchants typically do not obtain a physical copy of a signature, the credit card issuer will side with the customer
- because the merchant has no legally valid proof₅ that the customer ordered the merchandise.

3. Authenticity:

- Authenticity refers to the ability to identify the identity of a person or entity with whom you are dealing on the Internet.
- Authenticity tries to answer following questions:
 - ✓ How does the customer know that the website operator is who it claims to be?
 - ✓ How can the merchant be assured that the customer is really who she says she is?
- Authenticity ensures that someone who claims to be someone he/she is not is “spoofing” or misrepresenting himself.

4. Confidentiality

- Confidentiality refers to the ability to ensure that messages and data are available only to those who are authorized to view them.

5. Privacy

- refers to the ability to control the use of information a customer provides about himself or herself to an e-commerce merchant.
- E-commerce merchants have two concerns related to privacy.
 - ✓ They must establish internal policies that govern their own use of customer information
 - ✓ they must protect that information from illegitimate or unauthorized use.

- For example, if hackers break into an e-commerce site and gain access to credit card or other information, this violates not only the confidentiality of the data, but also the privacy of the individuals who supplied the information.

6. Availability

- Availability refers to the ability to ensure that an e-commerce site continues to function as intended.
- In simple words, availability means the ecommerce services must be available to customers without interruption.

TABLE 5.3

CUSTOMER AND MERCHANT PERSPECTIVES ON THE
DIFFERENT DIMENSIONS OF E-COMMERCE SECURITY

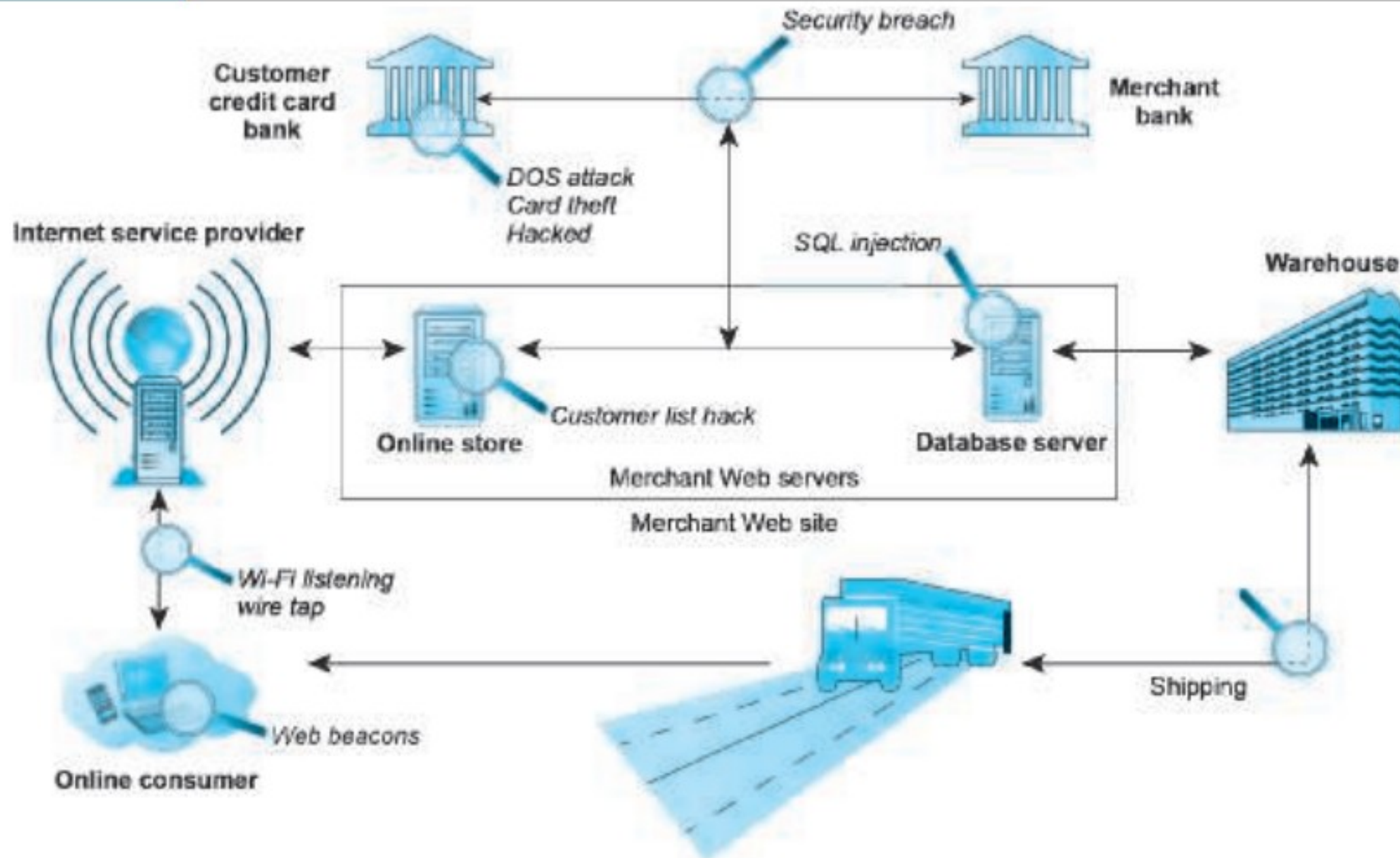
DIMENSION	CUSTOMER'S PERSPECTIVE	MERCHANT'S PERSPECTIVE
Integrity	Has information I transmitted or received been altered?	Has data on the site been altered without authorization? Is data being received from customers valid?
Nonrepudiation	Can a party to an action with me later deny taking the action?	Can a customer deny ordering products?
Authenticity	Who am I dealing with? How can I be assured that the person or entity is who they claim to be?	What is the real identity of the customer?
Confidentiality	Can someone other than the intended recipient read my messages?	Are messages or confidential data accessible to anyone other than those authorized to view them?
Privacy	Can I control the use of information about myself transmitted to an e-commerce merchant?	What use, if any, can be made of personal data collected as part of an e-commerce transaction? Is the personal information of customers being used in an unauthorized manner?
Availability	Can I get access to the site?	Is the site operational?

SECURITY THREATS IN THE E-COMMERCE ENVIRONMENT

- From a technology perspective, there are three key points of vulnerability when dealing with e-commerce:
 - the client
 - the server
 - the communications pipeline.

FIGURE 5.3

VULNERABLE POINTS IN AN E-COMMERCE TRANSACTION



Most common and most damaging forms of security threats to e-commerce consumers and site operators are:

- malicious code
- potentially unwanted programs
- Phishing
- hacking and cybervandalism
- credit card fraud/theft
- Spoofing
- Pharming
- spam (junk) websites (link farms)
- identity fraud
- Denial of Service (DoS) and DDoS attacks
- sniffing,

- poorly designed server and client software

Malicious code (sometimes referred to as “malware”) includes a variety of threats such as viruses, worms, Trojan horses, ransomware etc. Some malicious code, sometimes referred to as an exploit, is designed to take advantage of software vulnerabilities in a computer’s operating system, web browser, applications, or other software components.

(please read page 264-267 of Laudon-Traver book for details)

potentially unwanted programs (PUPs): PUPs are adware, browser parasites, spyware, and other applications that install themselves on a computer, such as rogue security software, toolbars, and PC diagnostic tools, typically without the user’s informed consent. Such programs are increasingly found on social network and user-generated content sites where users are fooled into downloading them. Once installed, these applications are usually difficult to remove from the computer. One example of a PUP is System Doctor, which infects PCs running Windows operating systems. System Doctor poses as a legitimate anti-spyware program when in fact it is malware that, when installed, disables the user’s security software, alters the user’s web browser, and diverts users to scam websites where more malware is downloaded.

Phishing is any deceptive, online attempt by a third party to obtain confidential information for financial gain. Phishing attacks typically do not involve malicious code but instead rely on straightforward misrepresentation and fraud, so-called “social engineering” techniques. One of the most popular phishing attacks is the e-mail scam letter.

Hacking, cybervandalism, and hacktivism

A hacker is an individual who intends to gain unauthorized access to a computer system. The term cracker is typically used to denote a hacker with criminal intent, although in the public press, the terms hacker and cracker tend to be used interchangeably. Hackers and crackers gain unauthorized access by finding weaknesses in the security procedures of websites and computer systems, often taking advantage of various features of the Internet that make it an open system that is easy to use. In the past, hackers and crackers typically were computer aficionados excited by the challenge of breaking into corporate and government websites. Sometimes they were satisfied merely by breaking into the files of an e-commerce site. Today, hackers have malicious intentions to disrupt, deface, or destroy sites (cybervandalism) or to steal personal or corporate information they can use for financial gain (data breach).

Hacktivism is politically motivated hacker. Hacktivists typically attack governments, organizations, and even individuals for political purposes, employing the tactics of cybervandalism, distributed denial of service attacks, data thefts, and doxing (gathering and exposing personal information of public figures, typically from emails, social network posts, and other documents). The most prominent hacktivist organization is Wikileaks

CREDIT CARD FRAUD/THEFT

- Theft of credit card data is one of the most feared occurrences on the Internet. Fear that credit card information will be stolen prevents users from making online purchases in many cases.
- In the past, the most common cause of credit card fraud was a lost or stolen card that was used by someone else.
- Then the trend changed in the form of employee theft of customer numbers and stolen identities (criminals applying for credit cards using false identities).
- Today, the most frequent cause of stolen cards and card information is the systematic hacking and looting of a corporate server where the information on millions of credit card purchases is stored.
- A central security issue of e-commerce is the difficulty of establishing the customer's identity.
- Currently there is no technology that can identify a person with absolute certainty. e.g., a lost or stolen card can be used until the card is cancelled.

SPOOFING and PHARMING

- Spoofing involves attempting to hide a true identity by using someone else's e-mail or IP address.
- For instance, a spoofed e-mail will have a forged sender e-mail address designed to mislead the receiver about who sent the e-mail.
- IP spoofing involves the creation of TCP/IP packets that use someone else's source IP address, indicating that the packets are coming from a trusted host.
- Most current routers and firewalls can offer protection against IP spoofing.
- Pharming is automatically redirecting a web link to an address different from the intended one, with the site masquerading as the intended destination.
- Links that are designed to lead to one site can be reset to send users to a totally unrelated site—one that benefits the hacker.

- spoofing and pharming may not directly damage files or network servers, they threaten the integrity of a site.
- For example, if hackers redirect customers to a fake website that looks almost exactly like the true site, they can then collect and process orders, effectively stealing business from the true site.
- Sometimes, the intent is to disrupt rather than steal. In this case, hackers can alter orders and then send them on to the true site for processing and delivery.
- As a result, Customers become dissatisfied with the improper order shipment, and the company suffers.
- Spoofing also threatens authenticity. (We do not know the true sender of message).

SPAM(JUNK) WEBSITES (LINK FARMS)

- Spam (junk) websites (also sometimes referred to as link farms) are sites that promise to offer some product or service, but in fact are just a collection of advertisements for other sites, some of which contain malicious code.
- For instance, you may search for “[name of town] weather,” and then click on a link that promises your local weather, but the site displays ads for weather-related products or other websites.
- Junk or spam websites typically appear on search results, and do not involve e-mail. These sites cloak their identities by using domain names similar to legitimate firm names, and redirect traffic to known spammer-redirection domains.

IDENTITY FRAUD

- Identity fraud involves the unauthorized use of another person's personal data, such as social security number, driver's license, and/or credit card numbers, as well as user names and passwords, for illegal financial benefit.
- Criminals can use such data to obtain loans, purchase merchandise, or obtain other services, such as mobile phone or other utility services.
- Cybercriminals employ techniques , such as spyware, phishing, data breaches, and credit card theft, for the purpose of identity fraud.
- Data breaches often lead to identity fraud.

SNIFFING AND MAN-IN-THE-MIDDLE ATTACKS

- A sniffer is a type of eavesdropping program that monitors information traveling over a network.
- When used legitimately, sniffers can help identify potential network trouble-spots, but when used for criminal purposes, they can be damaging and very difficult to detect.
- Sniffers enable hackers to steal proprietary information from anywhere on a network, including passwords, e-mail messages, company files, and confidential reports.
- For instance, in 2013, five hackers were charged in worldwide hacking scheme that targeted the corporate networks of retail chains, using sniffer programs to steal more than 160 million credit card numbers
- E-mail wiretaps are a variation on the sniffing threat.
- An e-mail wiretap is a method for recording or journaling e-mail traffic generally at the mail server level from any individual.
- E-mail wiretaps are used by employers to track employee messages, and by government agencies to surveil individuals or groups.

- A man-in-the-middle (MitM) attack also involves eavesdropping but is more active than a sniffing attack, (sniffing attack typically involves passive monitoring).
- In a MitM attack, the attacker is able to intercept communications between two parties who believe they are directly communicating with one another, when in fact the attacker is controlling the communications. This allows the attacker to change the contents of the communication.

DENIAL OF SERVICE (DOS) AND DISTRIBUTED DENIAL OF SERVICE (DDOS) ATTACKS

- In a Denial of Service (DoS) attack, hackers flood a website with useless pings or page requests that overwhelm the site's web servers.
- Increasingly, DoS attacks involve the use of bot networks and so-called "distributed attacks" built from thousands of compromised client computers.
- DoS attacks typically cause a website to shut down, making it impossible for users to access the site.
- For busy e-commerce sites, these attacks are costly; while the site is shut down, customers cannot make purchases.
- And the longer a site is shut down, the more damage is done to a site's reputation.
- Although such attacks do not destroy information or access restricted areas of the server, they can destroy a firm's online business.
- Often, DoS attacks are accompanied by attempts at blackmailing site owners to pay tens or hundreds of thousands of dollars to the hackers in return for stopping the DoS attack.

- A Distributed Denial of Service (DDoS) attack uses hundreds or even thousands of computers to attack the target network from numerous launch points.
- DoS and DDoS attacks are threats to a system's operation because they can shut it down indefinitely.
- Major websites have experienced such attacks, making the companies aware of their vulnerability and the need to continually introduce new measures to prevent future attacks.

POORLY DESIGNED SOFTWARE

- Many security threats prey on poorly designed software, in the operating system or in the application software, including browsers.
- There are always software flaws and vulnerabilities that hackers can exploit.
- For instance, SQL injection attacks take advantage of vulnerabilities in poorly coded web application software
 - ✓ that fails to properly validate or filter data entered by a user on a web page
 - ✓ Attacker can introduce malicious program code into a company's systems and networks.
 - ✓ An attacker can use this input validation error to send a rogue SQL query to the underlying database to access the database, plant malicious code, or access other systems on the network.
 - ✓ Large web applications have hundreds of places for inputting user data, each of which creates an opportunity for an SQL injection attack.

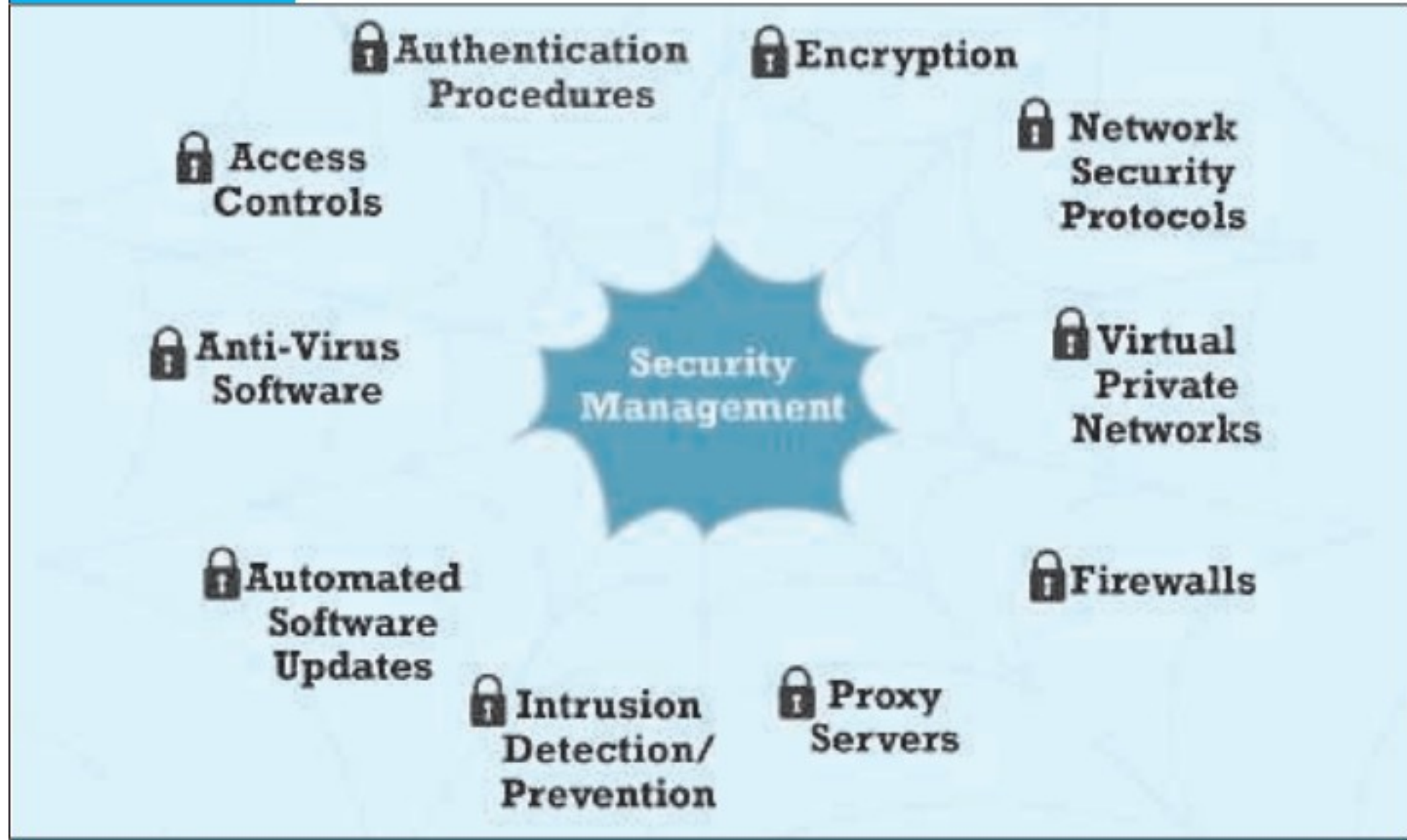
- Each year, security firms identify thousands of software vulnerabilities in Internet browsers, PC, Macintosh, and Linux software, as well as mobile device operating systems and applications.

Security mechanisms

- it is clear that the threats to e-commerce are very real, widespread, global, potentially devastating for individuals, businesses, and entire nations
- The threats are likely to be increasing in intensity along with the growth in e-commerce and the expansion of the Internet.
- There are two lines of defense:
 - technology solutions –develop a set of tools that can make it difficult for outsiders to invade or destroy a site.
 - policy solutions : mitigate the security threat with systematic organizational policy (planning)

FIGURE 5.5

TOOLS AVAILABLE TO ACHIEVE SITE SECURITY



PROTECTING INTERNET COMMUNICATIONS

- e-commerce transactions must flow over the public Internet
- security experts believe the greatest security threats occur at the level of Internet communications.
- The most basic tool to available to protect the security of Internet communications is message encryption

Encryption

- Encryption is the process of transforming plain text or data into cipher text that cannot be read by anyone other than the intended person (or device).
- The purpose of encryption is
 - (a) to secure stored information and
 - (b) to secure information transmission

- Encryption can provide four of the six key dimensions of e-commerce security :
 - Message integrity
 - Nonrepudiation
 - Authentication
 - Confidentiality
- The transformation of plain text to cipher text is accomplished by using a key or cipher.
- A key (or cipher) is any method for transforming plain text to cipher text.
- There are many types of ciphers (encryption methods)
 - Substitution ciphers – replace every letter with new letter
 - Transposition ciphers – change the positions(order) of letters
 - Block ciphers– Break plain text into fixed sized chunks and encrypt them separately

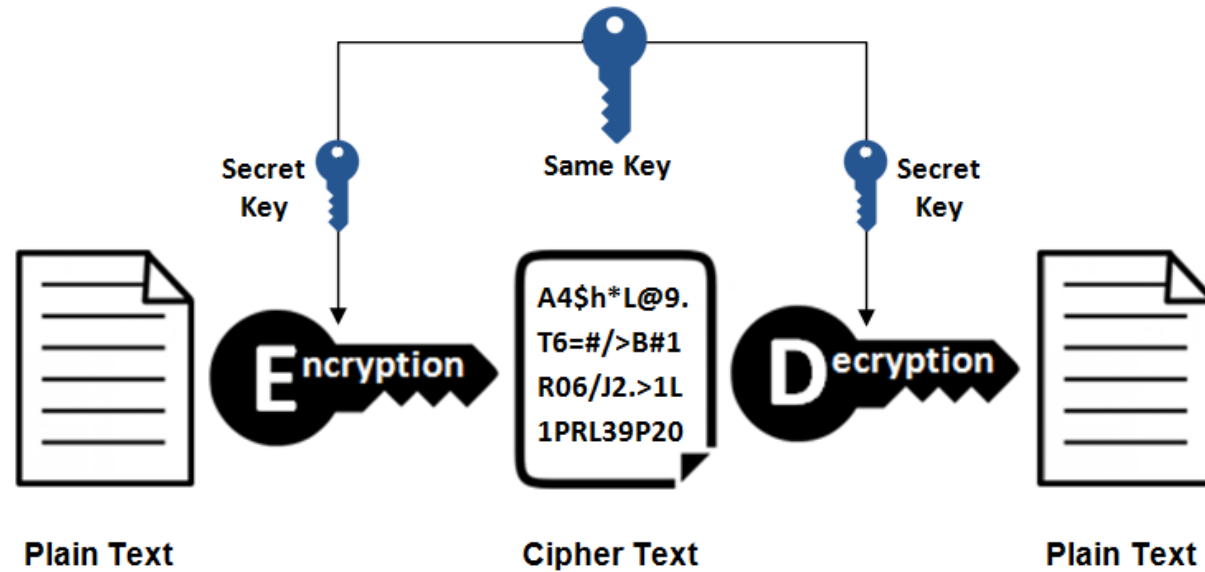
Types of encryption

1. Symmetric (secret) Key Cryptography
2. Asymmetric (public) key cryptography

1. Symmetric key cryptography

- Same key is used to encrypt and decrypt data.
- The key must be kept secret.
- If the message is to be sent over a network, the key must be shared by sender and receiver.
- Used in old days. But still used partly in Internet security
- Advantage: Fast
- Problems:
 - ✓ Prone to brute-force attack
 - ✓ How to share keys over the public network?
 - ✓ Need separate secret keys (usually a lot of keys) for anyone we transact with

Symmetric Encryption



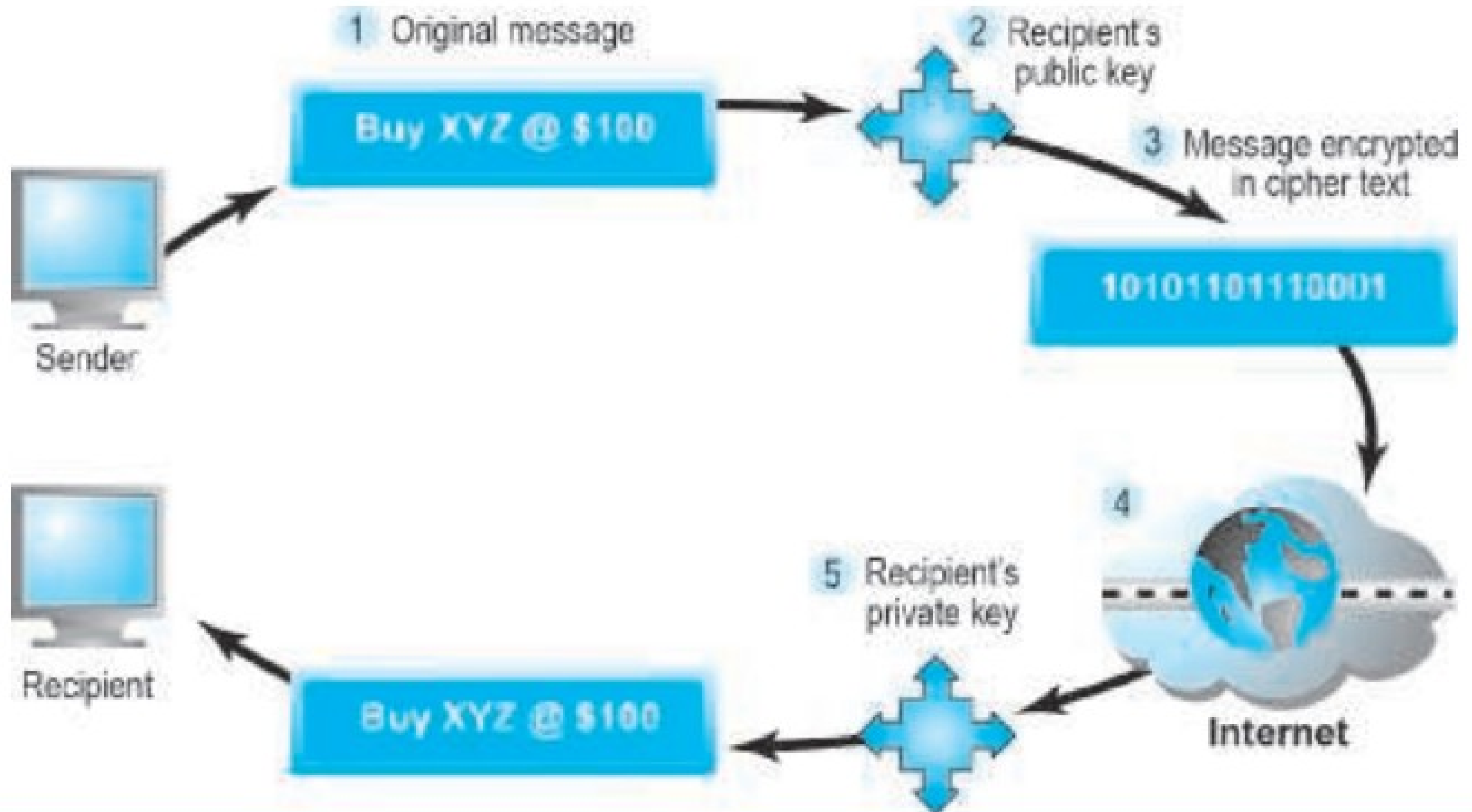
- In modern digital devices, the messages are represented with binary strings.
- So block ciphers are more popular. These methods divide messages into blocks of binary strings and encrypt them with key (also in the form of binary digits).
- The most powerful block ciphers is Advanced encryption standard (AES) which uses keys length of 128, 192, and 256 bits.

2. Public key cryptography:

- In 1976, a new way of encrypting messages called public key cryptography was invented by Whitfield Diffie and Martin Hellman.
- Public key cryptography (also referred to as asymmetric cryptography) solves the problem of exchanging keys.
- In this method, two mathematically related digital keys are used:
 - a public key and
 - a private key.
- The private key is kept secret by the owner, and the public key is widely disseminated.
- The public key can be used to encrypt the message and the private key is used to decrypt a message.
- Now we can easily share the public key over the internet and we don't need separate keys to transact with different parties.

FIGURE 5.6**PUBLIC KEY CRYPTOGRAPHY—A SIMPLE CASE**

STEP	DESCRIPTION
1. The sender creates a digital message.	The message could be a document, spreadsheet, or any digital object.
2. The sender obtains the recipient's public key from a public directory and applies it to the message.	Public keys are distributed widely and can be obtained from recipients directly.
3. Application of the recipient's key produces an encrypted cipher text message.	Once encrypted using the public key, the message cannot be reverse-engineered or unencrypted using the same public key. The process is irreversible.
4. The encrypted message is sent over the Internet.	The encrypted message is broken into packets and sent through several different pathways, making interception of the entire message difficult (but not impossible).
5. The recipient uses his/her private key to decrypt the message.	The only person who can decrypt the message is the person who has possession of the recipient's private key. Hopefully, this is the legitimate recipient.



Public Key Cryptography -- Digital Signatures and Hash Digests

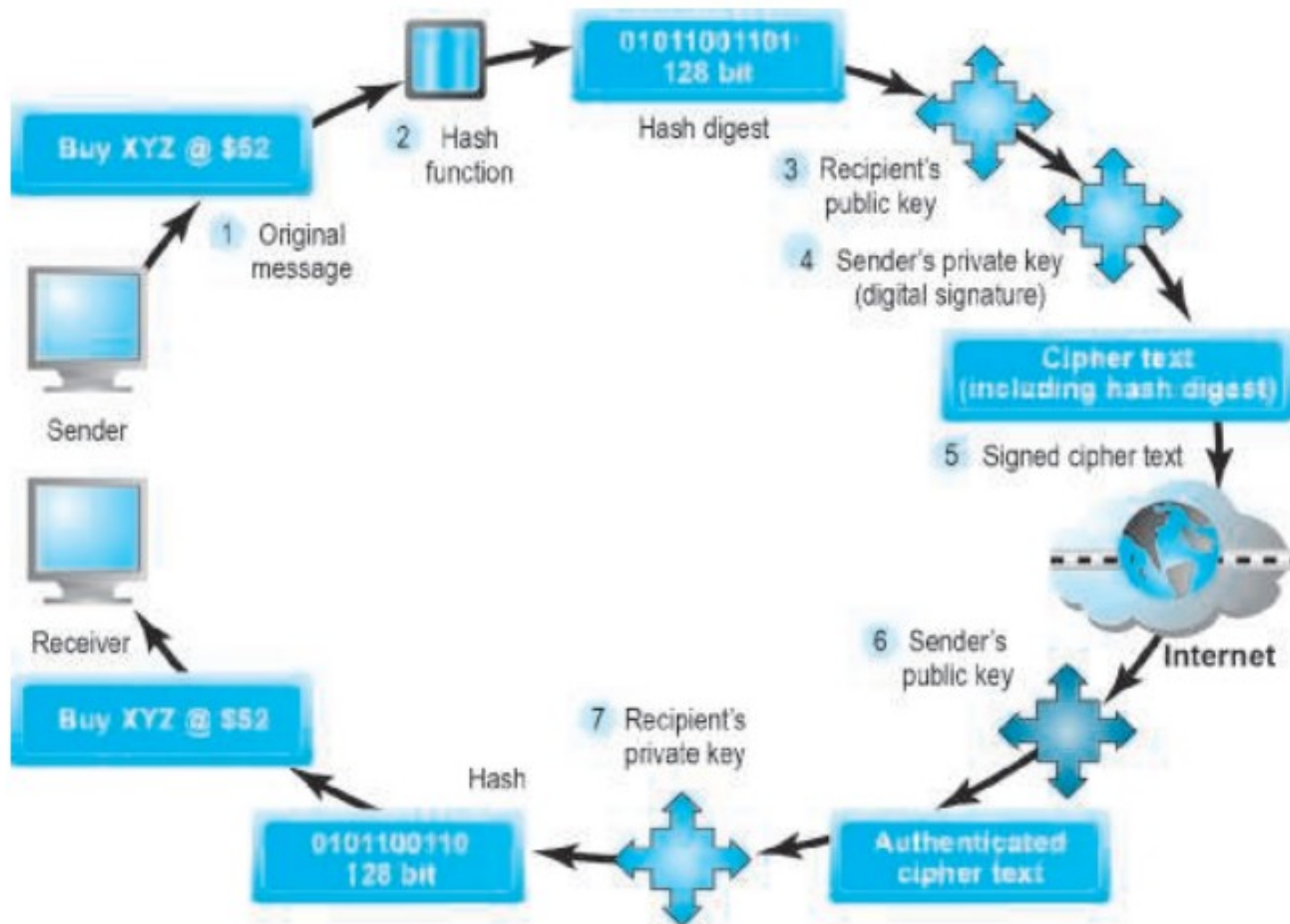
- In simple form of public key cryptography, some elements of security are missing.
- It provides confidentiality but it does not ensure:
 - Authentication-- prone to Man-in-the-middle attack
 - nonrepudiation
 - Integrity
- A more sophisticated use of public key cryptography can achieve authentication, nonrepudiation, and integrity
- How ?
 - Message digest via hash function
 - Digital signatures

- **Hash function** is used first to create a digest of the message to check integrity of a message and ensure it has not been altered in transit.
- A hash function is an algorithm that takes a message as input and produces a fixed-length number called a hash or message digest.
- Standard hash functions are available (MD4 and MD5 produce 128- and 160-bit hashes)
- These hash functions produce hashes that are unique to every message.
- Process:
 1. The results of applying the hash function are sent by the sender to the recipient.
 2. Upon receipt, the recipient applies the hash function to the received message and checks to verify the same result is produced. If so, the message has not been altered.
 3. The sender then encrypts both the hash result and the original message using the recipient's public key producing a single block of cipher text.

4. One more step is required to ensure the authenticity of the message and to ensure nonrepudiation, the sender encrypts the entire block of cipher text one more time using the sender's private key.
5. This produces a digital signature (also called an e-signature) or "signed" cipher text that can be sent over the Internet.
6. A digital signature is a close parallel to a handwritten signature. unique —only one person has the private key. Also, when used to sign a hashed document, the digital signature is also unique to the document, and changes for every document.
7. The recipient of the signed cipher text first uses the sender's public key to authenticate the message. Once authenticated, the recipient uses his or her private key to obtain the hash result and original message.
8. Finally, the recipient applies the same hash function to the original text, and compares the result with the result sent by the sender. If the results are the same, the recipient now knows the message has not been changed during transmission. The message has integrity.

FIGURE 5.7**PUBLIC KEY CRYPTOGRAPHY WITH DIGITAL SIGNATURES**

STEP	DESCRIPTION
1. The sender creates an original message.	The message can be any digital file.
2. The sender applies a hash function, producing a 128-bit hash result.	Hash functions create a unique digest of the message based on the message contents.
3. The sender encrypts the message and hash result using the recipient's public key.	This irreversible process creates a cipher text that can be read only by the recipient using his or her private key.
4. The sender encrypts the result, again using his or her private key.	The sender's private key is a digital signature. There is only one person who can create this digital mark.
5. The result of this double encryption is sent over the Internet.	The message traverses the Internet as a series of independent packets.
6. The receiver uses the sender's public key to authenticate the message.	Only one person can send this message, namely, the sender.
7. The receiver uses his or her private key to decrypt the hash function and the original message. The receiver checks to ensure the original message and the hash function results conform to one another.	The hash function is used here to check the original message. This ensures the message was not changed in transit.



- Early digital signature programs required the user to have a digital certificate, and were far too difficult for an individual to use.
- Newer programs are Internet-based and do not require users to install software, or understand digital certificate technology.
- DocuSign, Adobe eSign, and Sertifi are among a number of companies offering online digital signature solutions.
- Many insurance, finance, and surety companies now permit customers to electronically sign documents.
- **Note: The Electronic transaction Act of Nepal basically addresses the issue of validity of electronic documents via digital signatures**

Weakness of Public key cryptography

- Slow : Encrypting/decrypting large documents is significantly reduces transmission time and increases processing time.

Solution ??

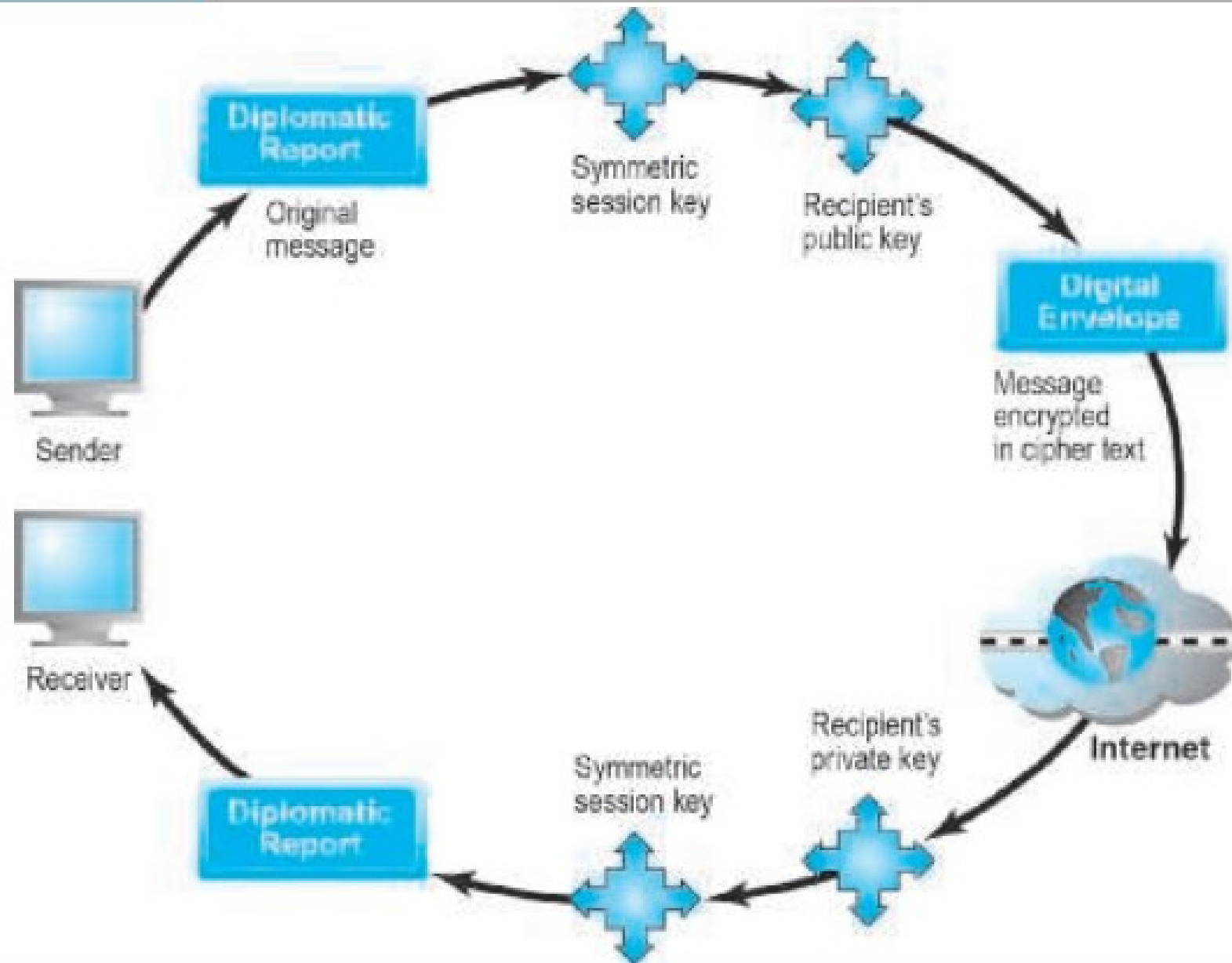
- For large documents:
 - Use symmetric key cryptography to encrypt/decrypt the document
 - Use public key cryptography to encrypt and transmit the symmetric key.
- This technique is called digital envelope

How digital envelope technique works?

- document is encrypted using a symmetric key.
- The symmetric key—which the recipient will require to decrypt the document—is itself encrypted, using the recipient's public key.
- So we have a “key within a key” (a digital envelope).
- The encrypted document and the digital envelope are sent across the Web.
- The recipient first uses his/her private key to decrypt the symmetric key
- Then the recipient uses the symmetric key to decrypt the documents.
- This method saves time because both encryption and decryption are faster with symmetric keys.

FIGURE 5.8

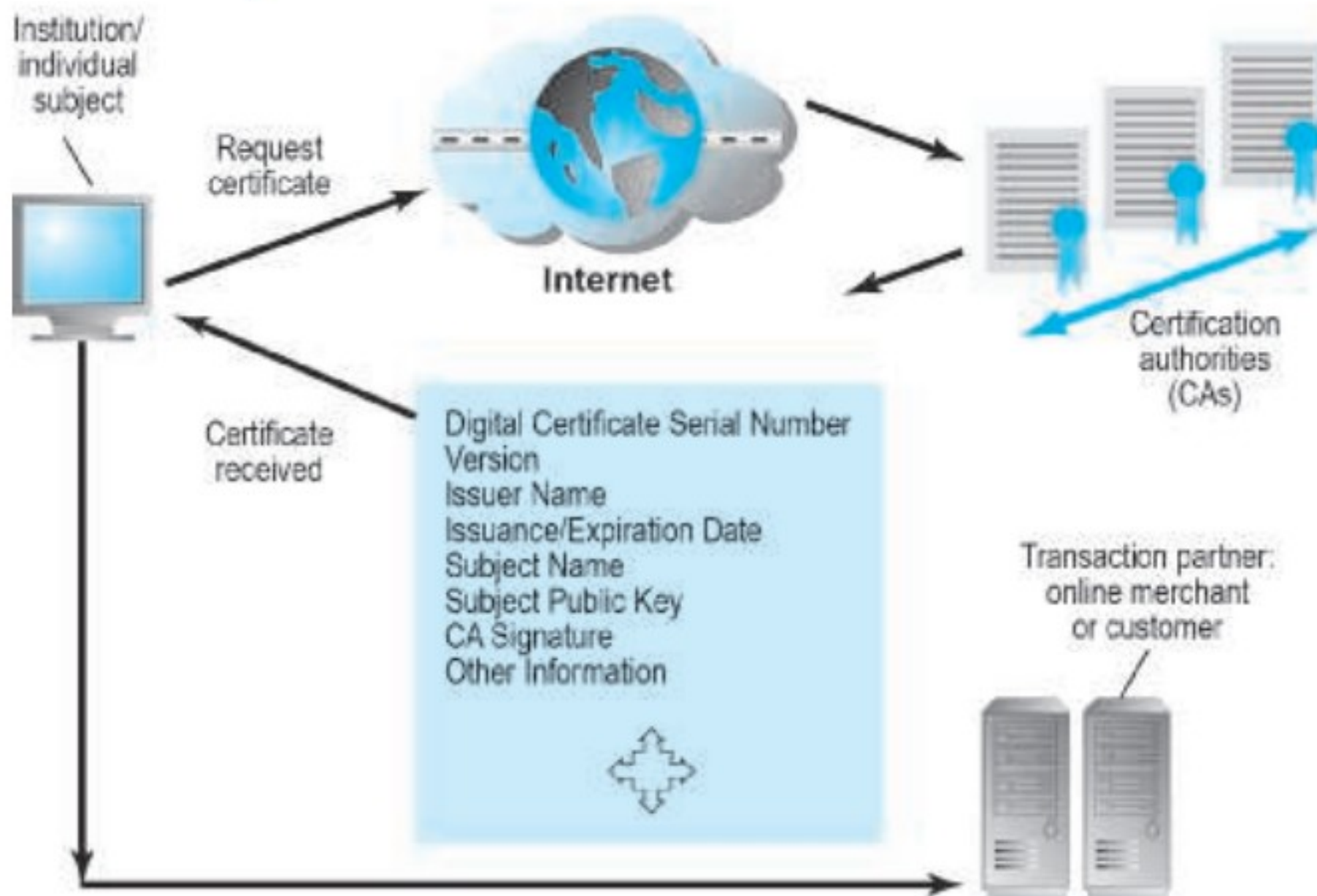
PUBLIC KEY CRYPTOGRAPHY: CREATING A DIGITAL ENVELOPE



Digital Certificates and Public Key Infrastructure (PKI)

- There are still some deficiencies in the message security techniques described previously.
- How do we know that people and institutions are who they claim to be?
 - Anyone can make up a private and public key combination and claim to be someone they are not.
 - Before we place an order with an online merchant such as Amazon, we want to be sure it really is Amazon you have on the screen and not a spoofer masquerading as Amazon.
- In the physical world, if someone asks who I am and I show a social security number, they may well ask to see a picture ID or a second form of certifiable or acceptable identification.
- Similarly, in the digital world, we need a way to know who people and institutions really are.

- Digital certificates, and the supporting public key infrastructure, are an attempt to solve the problem of digital identity.
- A digital certificate is a digital document issued by a trusted third-party institution known as a certification authority (CA)
- Typically digital certificate contains various information such as:
 - name of the subject or company,
 - subject's public key
 - digital certificate serial number
 - expiration date/issuance date
 - digital signature of the certification authority (the name of the CA encrypted using the CA's private key),
 - and other identifying information

FIGURE 5.9**DIGITAL CERTIFICATES AND CERTIFICATION AUTHORITIES**

- To create a digital certificate, the user generates a public/private key pair and sends a request for certification to a CA along with the user's public key.
- The CA verifies the information (how this is accomplished differs from CA to CA).
- The CA issues a certificate containing the user's public key and other related information.
- Finally, the CA creates a message digest from the certificate itself (just like a hash digest) and signs it with the CA's private key.
- This signed digest is called the signed certificate. We get a totally unique cipher text document—there can be only one signed certificate like this in the world.

- In the United States, private corporations such as VeriSign, browser manufacturers, security firms, and government agencies such as the U.S. Postal Service and the Federal Reserve issue CAs.
- Worldwide, thousands of organizations issue CAs. A hierarchy of CAs has emerged with less-well-known CAs being certified by larger and better-known CAs, creating a community of mutually verifying institutions.
- **In Nepal?**
 - Radiant CA is the leading CA in Nepal . (<https://radiantca.com.np/>)
 - Nepal Certifying Company (NCC) is the Management Partner/Registration Authority of Radiant CA. It has been established in 2013 with the initiation of implementation and promotion of Digital Signature Certificates and provide services in the field of digital security.
- There are many types of certificates: personal, institutional, web server, software publisher, and CAs themselves.

Public key infrastructure (PKI)

- PKI refers to the CAs and digital certificate procedures that are accepted by all parties.
- When we sign into a “secure” site, the URL will begin with “https” and a closed lock icon will appear on our browser.
- This means the site has a digital certificate issued by a trusted CA. So it guarantees that It is not a spoof site.

Use of digital certificates in e-commerce

- There are several ways the certificates are used in commerce.
- Before initiating a transaction, the customer can request the signed digital certificate of the merchant and decrypt it using the merchant's public key to obtain both the message digest and the certificate as issued.
- If the message digest matches the certificate, then the merchant and the public key are authenticated.
- The merchant may in return request certification of the user, in which case the user would send the merchant his or her individual certificate.
- There are many types of certificates: personal, institutional, web server, software publisher, and CAs themselves.

- PKI and CAs can also be used to secure software code and content for applications that are directly downloaded to mobile devices from the Internet.
- Using a technique referred to as code signing, mobile application developers use their private key to encrypt a digital signature.
- When end users decrypt the signature with the corresponding public key, it confirms the developer's identity and the integrity of the code.

Limitations of PKI

- PKI applies mainly to protecting messages in transit on the Internet and is not effective against insiders—employees—who have legitimate access to corporate systems including customer information.
- Issue of securing private key such as Where to put the private key ? -- Most private keys are be stored on insecure desktop or laptop computers.
- Problem of identity theft : someone else in the world may our personal ID papers, such as a social security card, to obtain a PKI authenticated online ID in our name.
- there is no guarantee the verifying computer of the merchant is secure
- Issues with certification:
 - CA are not authorities on the corporations or individuals they certify. For instance, how can a CA know about all the corporations within an industry to determine who is or is not legitimate?
 - concerns regarding method used by the CA to identify the certificate holder. There was a case when VeriSign acknowledged that it had mistakenly issued two digital certificates to someone fraudulently claiming to represent Microsoft.⁵¹

- Digital certificates have been hijacked by hackers, tricking consumers into giving up personal information.

PROTECTING NETWORKS (Network security)

- Three tools for Network security
 - **Firewalls**
 - **Proxy**
 - **Intrusion detection and prevention system**

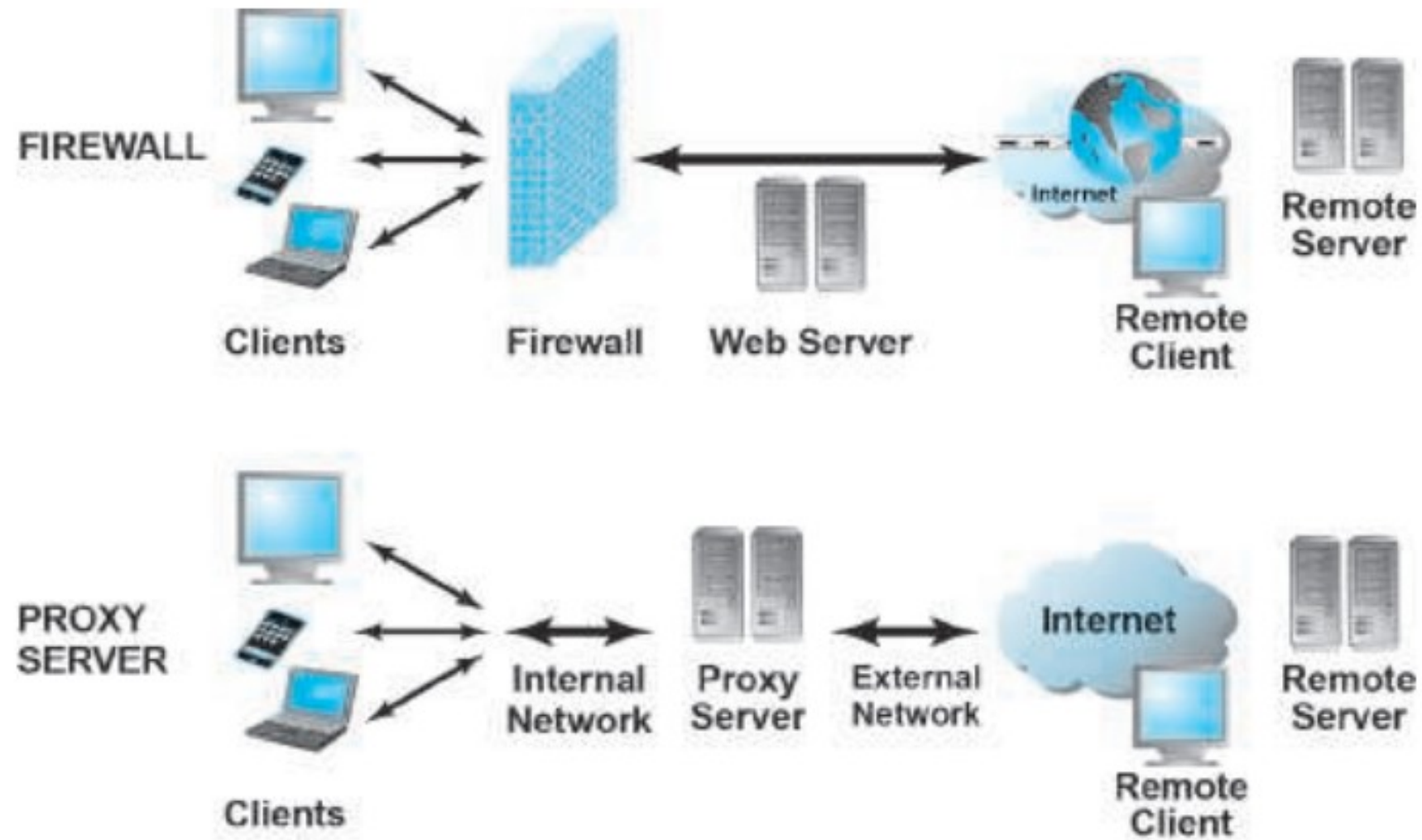
Firewalls:

- Firewalls and proxy servers are intended to build a wall around our network and the attached servers and clients, just like physical-world firewalls.
- A firewall refers to either hardware or software that filters communication packets and prevents some packets from entering or exiting the network based on a security policy.
- The firewall controls traffic to and from servers and clients, forbidding communications from untrustworthy sources, and allowing other communications from trusted sources.
- Every message that is to be sent or received from the network is processed by the firewall, which determines if the message meets security guidelines established by the business.
- If it does, it is permitted to be distributed, and if it doesn't, the message is blocked.

- Firewalls can filter traffic based on packet attributes such as source IP address, destination port or IP address, type of service (such as WWW or HTTP), the domain name of the source, and many other dimensions.
- Firewalls come as software or hardware or a combination of software and hardware. Advanced hardware firewalls are costly.

Proxy Servers

- Proxy servers (proxies) are software servers (often a dedicated computer) that handle all communications originating from or being sent to the Internet by local clients, acting as a spokesperson or bodyguard for the organization.
- Proxies act primarily to limit access of internal clients to external Internet servers
 - When a user on an internal network requests a web page, the request is routed first to the proxy server. The proxy server validates the user and the nature of the request, and then sends the request onto the Internet.
 - A web page sent by an external Internet server first passes to the proxy server. If acceptable, the web page passes onto the internal network web server and then to the client desktop.
- By prohibiting users from communicating directly with the Internet, companies can restrict access to certain types of sites, such as pornographic, auction, or stock-trading sites.

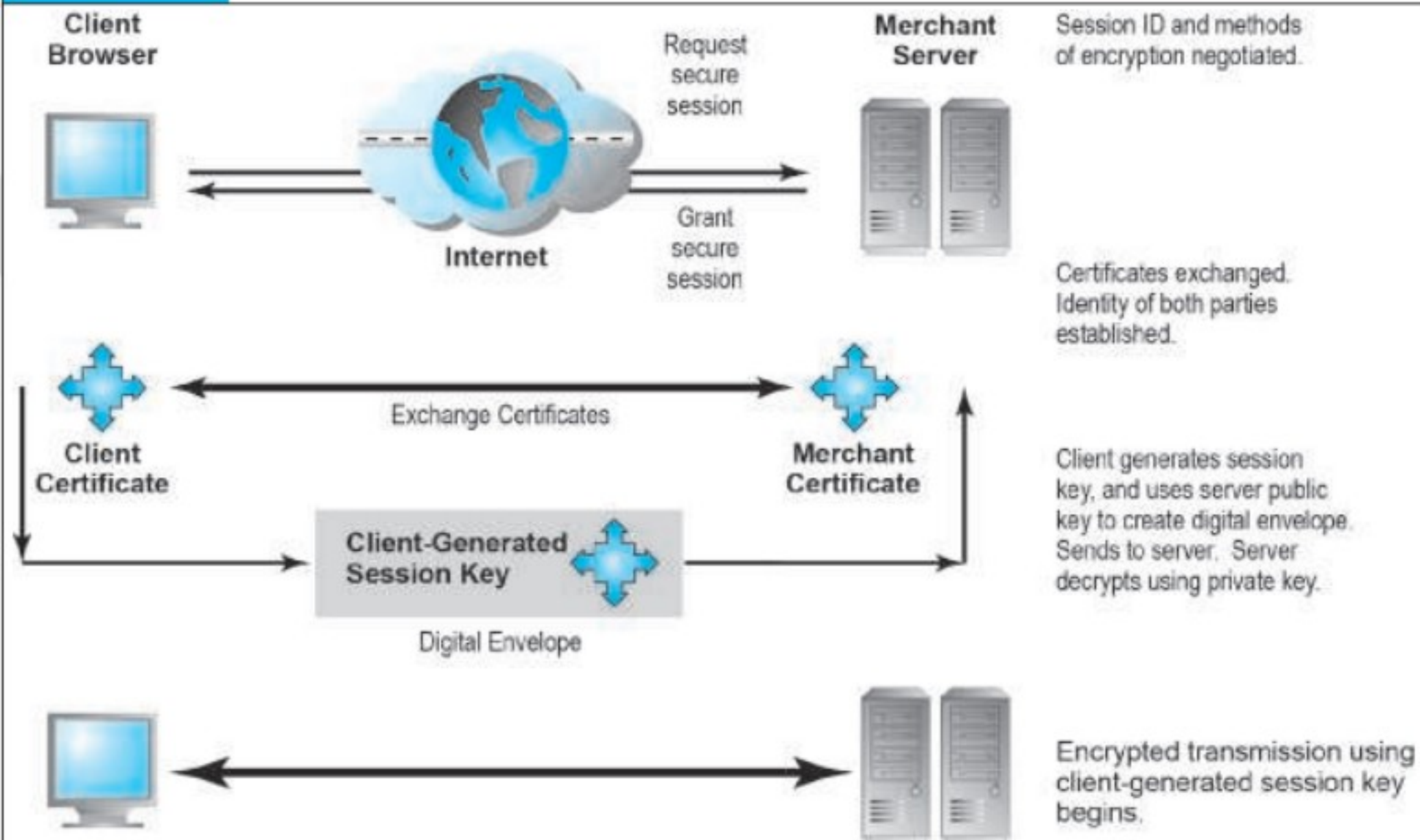
FIGURE 5.11**FIREWALLS AND PROXY SERVERS**

Intrusion Detection and Prevention Systems

- An intrusion detection system (IDS) examines network traffic, watching to see if it matches certain patterns or preconfigured rules indicative of an attack.
- If it detects suspicious activity, the IDS will set off an alarm alerting administrators and log the event in a database.
- An IDS is useful for detecting malicious activity that a firewall might miss.
- An intrusion prevention system (IPS) has all the functionality of an IDS, with the additional ability to take steps to prevent and block suspicious activities.
- For instance, an IPS can terminate a session and reset a connection, block traffic from a suspicious IP address, or reconfigure firewall or router security controls.

SECURING CHANNELS OF COMMUNICATION

- The concepts of public key cryptography are used for securing channels of communication.
- The most common form of securing channels is through the Secure Sockets Layer (SSL) and Transport Layer Security (TLS) protocols.
 - When we receive a message from a server on the Web with which we will be communicating through a secure channel, this means we will be using SSL/TLS to establish a secure negotiated session.
 - Notice that the URL changes from HTTP to HTTPS.
 - A secure negotiated session is a client- server session in which the URL of the requested document, along with the contents, contents of forms, and the cookies exchanged, are encrypted.
 - Through a series of handshakes and communications, the browser and the server establish one another's identity by exchanging digital certificates, decide on the strongest shared form of encryption, and then proceed to communicate using an agreed-upon session key.
 - A session key is a unique symmetric encryption key chosen just for this single secure session. Once used, it is gone forever.
 - In practice, most private individuals do not have a digital certificate. In this case, the merchant server will not request a certificate, but the client browser will request the merchant certificate once a secure session is called for by the server.

FIGURE 5.10**SECURE NEGOTIATED SESSIONS USING SSL/TLS**

Advantages/Limitations of SSL/TLS

- SSL/TLS provides data encryption, server authentication, optional client authentication, and message integrity for TCP/IP connections.
- SSL/TLS addresses the issue of authenticity by allowing users to verify another user's identity or the identity of a server.
- It also protects the integrity of the messages exchanged.
- However, once the merchant receives the encrypted credit and order information, that information is typically stored in unencrypted format on the merchant's servers.
- While SSL/TLS provides secure transactions between merchant and consumer, it only guarantees server-side authentication. Client authentication is optional.
- SSL/TLS cannot provide irrefutability—consumers can order goods or download information products, and then claim the transaction never occurred.

